Laboratorio 5

Responsable: Brandonaguicede

Repositorio:
https://github.com/Brandonaguicede/lab6pa

Bitácora de verificación - 2 de noviembre de 2026

Se ejecutó UNA Chat localmente con frontend y backend reales y sesión de prueba Tester.

Resultados: 31 pruebas unitarias, 20 de integración y 4 end-to-end aprobadas.

La evidencia de inyección muestra la versión corregida actual. No es una captura histórica de la versión vulnerable.

Snyk detectó 1 vulnerabilidad alta y 2 medias en dependencias de desarrollo. La alta de picomatch no tiene una versión corregida disponible según el aviso consultado. El requisito permanece pendiente; no se ignoraron hallazgos.

Las pruebas locales no acreditan el acceso real con Auth0 en producción. Se adjuntan los registros originales.

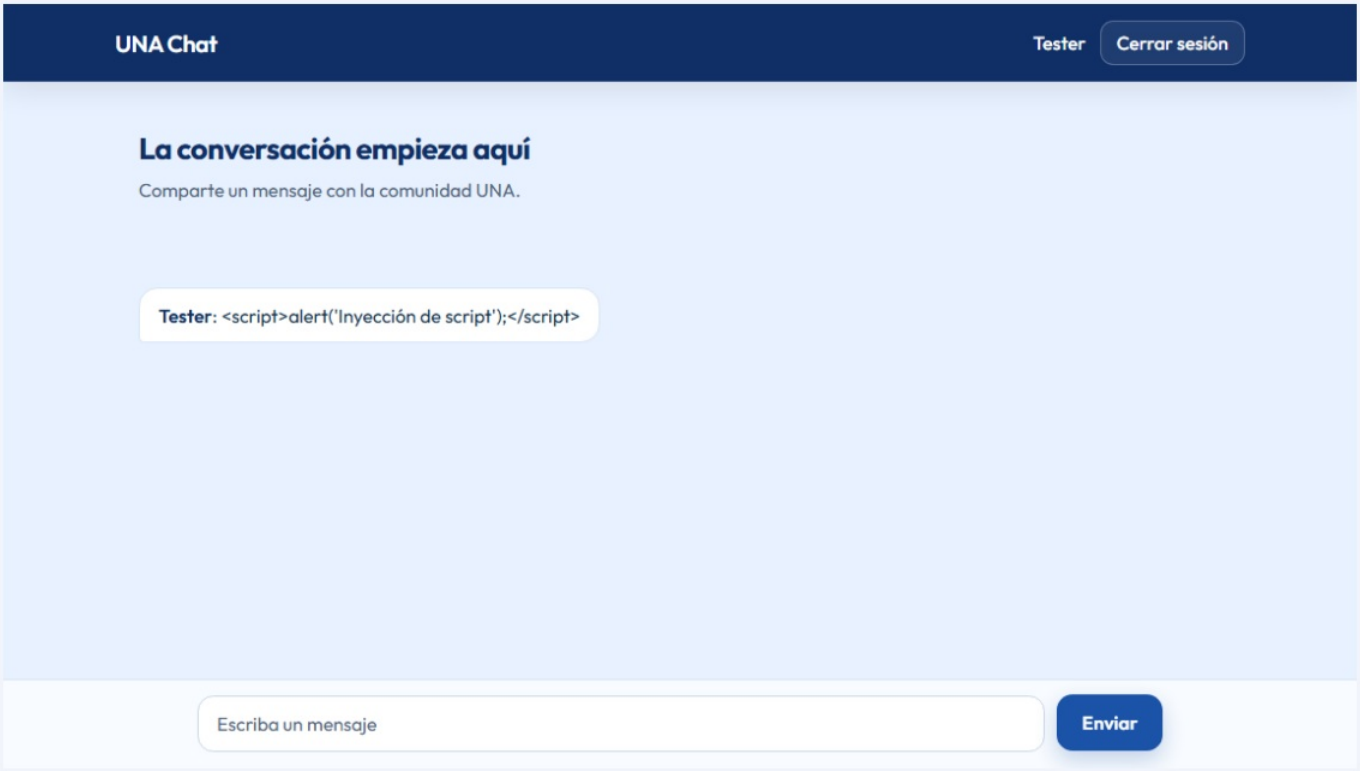
Entregar los JPG y repositorio.txt; confirmar con el docente si también solicita este PDF debido a las indicaciones contradictorias del enunciado.

Evidencia 1 · Inyección de scripts

Brandonaguicede · Laboratorio 5 · https://github.com/Brandonaguicede/lab6pa

Resultado observado en la **versión corregida actual**, con sesión de prueba Tester. No es una captura histórica de la versión vulnerable.

```
<script>alert('Inyección de script');</script>
Diálogos alert detectados: 0
Elementos script insertados: 0
Resultado: el payload se muestra como texto.
```



Evidencia 2 · Pruebas unitarias

Brandonaguicede · Laboratorio 5 · https://github.com/Brandonaguicede/lab6pa

```
$ npm test



  unalib
    funcion is_valid_phone
      √ deberia devolver true para 8297-8547
      √ deberia devolver false para 8297p-8547
    funcion is_valid_url_image
      √ deberia devolver true para http://image.com/image.jpg
      √ deberia devolver true para http://image.com/image.gif
    funcion is_valid_yt_video
      √ deberia devolver true para https://www.youtube.com/watch?v=qYwlqx-JLok
    validacion de URLs de imagenes
      √ acepta la extension .jpg
      √ acepta la extension .jpeg
      √ acepta la extension .gif
      √ acepta la extension .png
      √ acepta la extension .bmp
      √ acepta la extension .webp
      √ acepta query string
      √ rechaza una URL que no es imagen
      √ rechaza esquemas peligrosos (javascript:, data:)
      √ rechaza URLs que intentan salirse del atributo src
Es una imagen!
      √ validateMessage convierte una URL de imagen en una etiqueta <img>
    validacion de URLs de videos
      √ acepta youtube.com/watch?v=
      √ acepta youtu.be/
      √ rechaza un id de YouTube invalido
      √ rechaza otro dominio con apariencia de YouTube
      √ acepta videos directos mp4 y webm
      √ rechaza una URL que no es video
Es un video!
      √ validateMessage inserta un reproductor iframe para YouTube
Es un video!
      √ validateMessage inserta un reproductor <video> para mp4
    prevencion de inyeccion de scripts
Es un texto!
      √ escapa <script> en el mensaje
Es un texto!
      √ escapa etiquetas con manejadores de eventos
Es un texto!
      √ escapa HTML en el nombre de usuario
Es un texto!
      √ reemplaza un color malicioso por uno seguro
Es un texto!
      √ un mensaje con texto mas una URL no se interpreta como HTML
      √ un JSON invalido se devuelve escapado
      √ un mensaje vacio o no string no rompe la validacion


  31 passing (15ms)


Exit code: 0
```

Evidencia 3 · Pruebas de integración

Brandonaguicede · Laboratorio 5 · https://github.com/Brandonaguicede/lab6pa

```
$ npm run test:integration

  console.log
    Es una imagen!

      at Object.log [as validateMessage] (libs/unalib.js:134:19)

  console.log
    Es un video!

      at Object.log [as validateMessage] (libs/unalib.js:142:19)

  console.log
    Es un video!

      at Object.log [as validateMessage] (libs/unalib.js:138:19)

  console.log
    Es un texto!

      at Object.log [as validateMessage] (libs/unalib.js:146:19)

  console.log
    Es un texto!

      at Object.log [as validateMessage] (libs/unalib.js:146:19)

  console.log
    Es un texto!

      at Object.log [as validateMessage] (libs/unalib.js:146:19)

  console.log
    Es un texto!

      at Object.log (libs/unalib.js:146:19)

  console.log
    Es un texto!

      at Object.log [as validateMessage] (libs/unalib.js:146:19)

  console.log
    Es un texto!

      at Object.log [as validateMessage] (libs/unalib.js:146:19)

  console.log
    Es un texto!

      at Object.log [as validateMessage] (libs/unalib.js:146:19)

Test Suites: 3 passed, 3 total
Tests:       20 passed, 20 total
Snapshots:   0 total
Time:        3.075 s
Ran all test suites matching tests/integration.

Exit code: 0
```

Evidencia 4 · Pruebas end-to-end

Brandonaguicede · Laboratorio 5 · https://github.com/Brandonaguicede/lab6pa

```
$ npx playwright test --project=chromium --headed


Running 4 tests using 1 worker

  ok 1 [chromium] › tests\e2e\chat.spec.js:18:1 › muestra una imagen y termina de cargar (2.3s)
  ok 2 [chromium] › tests\e2e\chat.spec.js:26:1 › muestra un reproductor de video directo y carga el contenido (2.0s)
  ok 3 [chromium] › tests\e2e\chat.spec.js:34:1 › muestra el reproductor de YouTube embebido y carga el contenido (1.6s)
  ok 4 [chromium] › tests\e2e\chat.spec.js:43:1 › un script inyectado no se ejecuta y el mensaje queda saneado (2.1s)

  4 passed (14.7s)
(node:32992) Warning: The 'NO_COLOR' env is ignored due to the 'FORCE_COLOR' env being set.
(Use `node --trace-warnings ...` to show where the warning was created)

Exit code: 0
```

Paso 11 · Escaneo Snyk

Brandonaguicede · Laboratorio 5 · https://github.com/Brandonaguicede/lab6pa

Escaneo real incluyendo dependencias de desarrollo. El registro completo se adjunta en logs/snyk.txt.

```
$ npx snyk test --dev
Tested 427 dependencies for known issues, found 3 issues, 11 vulnerable paths.
Open Security issues: 3
 ✗ [MEDIUM] Prototype Pollution
   Finding ID: SNYK-JS-DEEPMERGE-19964053
 ✗ [MEDIUM] Asymmetric Resource Consumption (Amplification)
   Finding ID: SNYK-JS-MINIMATCH-22111072
 ✗ [HIGH] Regular Expression Denial of Service (ReDoS)
   Finding ID: SNYK-JS-PICOMATCH-21248802
  ✗ Prototype Pollution [MEDIUM] [https://security.snyk.io/vuln/SNYK-JS-DEEPMERGE-19964053] in deepmerge@4.3.1
  ✗ Asymmetric Resource Consumption (Amplification) [MEDIUM] [https://security.snyk.io/vuln/SNYK-JS-MINIMATCH-22111072] in
minimatch@10.2.6
  ✗ Regular Expression Denial of Service (ReDoS) [HIGH] [https://security.snyk.io/vuln/SNYK-JS-PICOMATCH-21248802] in
picomatch@2.3.2
│   Total security issues: 3                                                    │
│   Open   : 3 [ 0 CRITICAL  1 HIGH  2 MEDIUM  0 LOW ]                         │
Exit code: 1
```

Pendiente: la vulnerabilidad alta SNYK-JS-PICOMATCH-21248802 no tiene una versión corregida disponible según el aviso consultado. No se declara reparada ni se ha ignorado.

Referencia: https://security.snyk.io/vuln/SNYK-JS-PICOMATCH-21248802